Document ID: VIB-GOV-RSK-024 Classification: INTERNAL CONFIDENTIAL (External Extracts Permitted)
Effective Date: 2024-04-01 Version: 5.1

Document Owner: National Head of Corporate Risk and Compliance

Risk Management Framework: VI Business (India)

1. Executive Purpose and Document Scope

The Risk Management Framework (RMF) dictates how VI Business (India) proactively identifies, quantifies, and mitigates operational and commercial threats before they impact our enterprise customers.

This document serves as proof to enterprise Chief Risk Officers (CROs) that VI Business does not merely react to failures but operates a formal, ISO 31000-aligned risk governance structure. It provides specific, auditable methodologies used to prevent catastrophic SLA breaches across our Managed Network and Security portfolios.

2. Definitions, Assumptions, and Applicability

Definitions:

- **ALARP:** As Low As Reasonably Practicable (Target risk state).
- **Residual Risk:** The threat level remaining after mitigation controls are applied.
- **Risk Owner:** The specific VIL Senior Vice President accountable for the risk.

Assumptions:

- Risk assessment is a continuous lifecycle, not a one-time project phase.
- Zero-risk is mathematically impossible in telecommunications; the RMF manages risk within the Board-approved corporate risk appetite.

Applicability:

- **Target Audience:** Bid Writers, Transition Managers, Corporate Auditors.
- **Scope:** Managed Network Service deployments, SOC operations, and massive CAPEX infrastructure upgrades.

3. Risk Taxonomy (Categorization)

To ensure systematic tracking within the ServiceNow Governance, Risk, and Compliance (GRC) module, risks are strictly categorized:

1. **Technical/Operational:** Hardware EoL, unpatched vulnerabilities, catastrophic fiber cuts on non-redundant rings.
2. **Commercial/Financial:** Currency fluctuation impacting OEM hardware imports, massive SLA penalty triggers.
3. **Regulatory/Compliance:** Changes to DoT (Department of Telecommunications) OSP routing rules, DPDP Act 2023 breach fines.

4. **Logistical:** Supply chain delays for active Cisco/Fortinet hardware holding up a 5,000-site deployment.

4. Assessment Method (Risk Scoring Matrix)

Risks are mathematically scored using a standardized 5x5 Probability vs. Impact matrix.

- **Probability (1-5):** 1 = Rare (<5% chance in 12 months), 5 = Almost Certain (>90% chance).
- **Business Impact (1-5):** 1 = Negligible (< INR 1 Lakh impact), 5 = Catastrophic (> INR 5 Crore impact or national brand damage).
- **Risk Score (1-25):** Probability x Business Impact.

Score Range	Classification	Required Action
1 - 6	Low (Green)	Accept Risk. Monitor quarterly.
8 - 12	Medium (Amber)	Mitigate. Implement controls within 90 days.
15 - 20	High (Red)	Mitigate Immediately. Weekly C-Suite review.
25	Critical (Black)	Cease Operations. Immediate CEO intervention.

5. Mitigation Planning and Residual Risk Handling

When a risk scores 'Medium' or above, the designated Risk Owner must select a formal containment strategy:

1. **Avoid:** Alter the deployment architecture to sidestep the threat (e.g., refusing to deploy an unencrypted radio link).
2. **Mitigate:** Implement compensating controls (e.g., deploying SD-WAN with dual-LTE to mitigate high single-fiber cut risks in rural areas).
3. **Transfer:** Shift financial liability (e.g., via the corporate E&O Insurance Policy).
4. **Accept:** Formal acknowledgment that the cost of mitigation drastically exceeds the cost of the impact.

Residual Risk Handling: If the Residual Risk (score post-mitigation) remains 'High' (15+), it *cannot* be accepted by a Project Manager. It must be formalized in a Risk Acceptance Document (RAD) and signed by the Chief Enterprise Business Officer (CEBO) or the Enterprise CISO.

6. Ownership Model and Escalation Thresholds

Risk cannot be nebulously assigned to "a department." Every entry in the Risk Register requires a specific human owner.

- **PMP / Service Delivery Manager (SDM):** Owns Low/Medium risks specific to an individual customer rollout.
- **National Head of Operations:** Escalate High (Red) operational risks here (e.g., a systemic firmware defect impacting multiple customers).
- **Enterprise CISO:** Escalate all High/Critical data sovereignty or cyber-breach risks here.

7. Risk Review Cadence

The RMF mandates a strict schedule to prevent the Risk Register from becoming stagnant.

- **Weekly:** Project-specific RAID logs (Risks, Assumptions, Issues, Dependencies) reviewed in the tactical customer governance bridge.

- **Monthly:** The Enterprise Risk Management (ERM) Committee reviews all 'High' overarching systemic risks.
- **Annually:** The entire enterprise risk posture is audited by the external ISO 27001 / ISO 20000-1 surveillance auditors.

8. Constraints, Exclusions, and Dependency Notes

- **Customer-Owned Risk:** VI Business assumes zero liability for risks introduced by architecture explicitly demanded by the customer against VI Business engineering advice (e.g., a customer mandating a single-point-of-failure firewall to save money). This is documented as a formal 'Customer Accepted Risk'.

9. Proposal-Use Guidance

- **Addressing Risk Questionnaires:** When an RFP asks, "How do you manage delivery risk?", extract Section 4 (The Matrix) directly into the response to prove we use mathematical quantification rather than subjective guessing.
- **Defending Deployment Delays:** Use the framework to show that a delay was caused by "Avoiding" a Critical risk (e.g., refusing to cut over a site because the customer's UPS power was unstable), thus protecting the customer's core business.

10. Governance and Ownership

- **Owner:** National Head of Corporate Risk and Compliance
- **Reviewers:** Enterprise Legal, Enterprise CISO.
- **Update Cadence:** Annual, aligned with the release of the VIL Corporate Annual Report.